Threat and Vulnerability Identification

Asset Name	Asset Description	Associated Threats	Potential Vulnerabilities	Mitigation Notes
EE-commerce Platform (Website & Mobile App)	Customer facing platform handling purchases, logins, and payment processing.	• Credential stuffing • Web application attacks (SQL injection, XSS) • Payment fraud	• Weak password policies • Lack of MFA for customers • Insecure API endpoints	• Implement MFA for users • Use Web Application Firewall (WAF) • Regular penetration testing • Secure coding practices (OWASP)
Customer Data (PII & Purchase History)	Sensitive customer data stored in CRM (Salesforce) and databases.	• Data breach • Insider threat • Third-party vendor leak	• Over-permissioned access (RBAC misconfigura tion) • Third-party integrations with weak security • Lack of encryption in some areas	• Data encryption (at rest & in transit) • Strict access control (least privilege) • Vendor risk assessment • Data Loss Prevention (DLP)
Cloud Infrastructure (AWS)	Hosts applications, databases, and services.	• Cloud misconfigura tion • Unauthorized access • Ransomware	• Open S3 buckets • Weak IAM roles • Poor monitoring/l ogging	• Enable AWS security tools (GuardDuty, CloudTrail) • Regular audits • Strong IAM policies • Backup and disaster recovery plan

Risk Criteria

Criteria	Description
Risk Description	**1. Phishing Attack Leading to Credential Compromise** **2. Third-Party Vendor Data Breach** **3. Ransomware Attack on Internal Systems**
Assets at Risk	1. Employees may fall victim to phishing emails, leading to credential theft and unauthorized system access. 2. A third-party vendor may expose customer data due to weak security controls. 3. Malware could encrypt company systems causing downtime and financial loss.
Threat	1. Employee accounts, CRM (Salesforce), internal systems 2. Customer email addresses, personal data 3. POS systems, ERP (SAP), AWS infrastructure
Vulnerability	1. Lack of advanced phishing awareness, no enforced MFA everywhere 2. Lack of vendor security assessment 3. BYOD risks, endpoint security gaps
Existing Controls	1. Basic security awareness training, antivirus 2. Basic contracts, limited monitoring 3. Antivirus, firewall
Inherent Risk Rating	1. **EXTREME** **2. HIGH** 3. **EXTERME**
Residual Risk Rating	**1. HIGH** **2. MEDIUM** **3. HIGH**
Likelihood	1. For Inherent Risk : **Likelihood:** 5 (Almost Certain) For Residual Risk: **Likelihood:** 4 (Likely) 2. For Inherent Risk : **Likelihood:** 4 (Likely) For Residual Risk: **Likelihood:** 3(Possible) 3. For Inherent Risk : **Likelihood:** 4 (Likely) For Residual Risk: **Likelihood:** 3(Possible)

Criteria	Description
Consequence	1. For Inherent Risk : **Consequence:** 5 (Almost Certain) For Residual Risk: **Consequence:** 4 (Likely) 2. For Inherent Risk : **Consequence:** 4 (Major) For Residual Risk: **Consequence:** 3 (Moderate) 3. For Inherent Risk : **Consequence:** 5 (Extreme) For Residual Risk: **Consequence:** 4 (Major)
Rating	1. For Inherent Risk : Ratting : EXTREME For Residual Risk: Ratting: High 2. For Inherent Risk : **Ratting : high** For Residual Risk: **Ratting : Medium** 3. For Inherent Risk : **Ratting: Extreme** For Residual Risk: **Ratting: High**

Criteria	Description
Mitigations	1. For 1st Risk • Enforce MFA for all systems • Advanced phishing simulations • Email filtering (anti-phishing gateway) • Zero Trust access 2. For 2nd Risk • Vendor risk management program • Security audits of third parties • Data sharing minimization • Legal compliance clauses 3. For 3rd Risk • Endpoint Detection & Response (EDR) • Regular backups (offline) • Network segmentation • Patch management
Risk Owner	1. IT Security Manager 2. Vendor Management Team 3. IT Operations Team

Risk Assessment

Complete this assessment for at least 3 risks.

Risk Details			
Risk ID	R001	**Date Identified**	18/03/2026
Risk Title	Phishing-based Credential Theft	**Review Date**	18/06/2026
Risk Identification			

Risk Description	Employees may fall victim to phishing emails, leading to credential theft and unauthorized system access.	
Assets at Risk	Employee accounts, CRM (Salesforce), internal systems	
Threat	Cybercriminals (phishing attackers)	
Vulnerability	Lack of advanced phishing awareness, no enforced MFA everywhere	
Existing Controls	Basic security awareness training, antivirus	
Inherent Risk Analysis		
Likelihood	**Consequence**	**Inherent Risk Rating**
5 (Almost Certain)	4(Major)	EXTREME
Residual Risk Analysis		
Likelihood	**Consequence**	**Residual Risk Rating**
4(Likely)	3(Moderate)	HIGH
Risk Treatment		
Mitigations	• Enforce MFA for all systems • Advanced phishing simulations • Email filtering (anti-phishing gateway) • Zero Trust access	
Risk Monitoring and Review		
Risk Owner	IT Security Manager	

To	management@retailnova.com
Cc	itsecurity@retailnova.com
Bcc	audit@retailnova.com

Subject	**Subject:** Identification of Key Cybersecurity Risks at RetailNova
	Dear Sir/Madam, I am writing to inform you about three major cybersecurity risks identified during the recent assessment of RetailNova's systems. The first risk involves phishing attacks that may lead to credential compromise. Employees could be targeted through malicious emails, allowing attackers to gain unauthorized access to critical systems such as CRM and internal platforms. The second risk is related to third-party vendors. Weak security controls at external partners may result in data leakage, as previously experienced, potentially exposing sensitive customer information and harming the company's reputation. The third risk concerns ransomware attacks on internal systems, including POS systems, SAP, and cloud infrastructure. Such attacks could cause severe operational disruption, financial losses, and downtime if not properly mitigated. These risks are categorized as high to extreme and require immediate attention. It is recommended to implement stronger security measures such as multi-factor authentication, enhanced vendor risk management, and advanced endpoint protection. Kindly review these findings and consider appropriate actions to mitigate the identified risks. Thank you for your attention. Yours sincerely, Souvik Dutta Cybersecurity Analyst RetailNova Pty Ltd

Risk Details			
Risk ID	R002	**Date Identified**	18/03/2026
Risk Title	Third -Party Data Leakage	**Review Date**	18/06/2026
Risk Identification			
Risk Description	A third-party vendor may expose customer data due to weak security controls.		
Assets at Risk	Customer email addresses, personal data		
Threat	External vendors / supply chain attack		

Vulnerability	Lack of vendor security assessment	
Existing Controls	Basic contracts, limited monitoring	
Inherent Risk Analysis		
Likelihood	**Consequence**	**Inherent Risk Rating**
4(Likely)	4 (Major)	HIGH
Residual Risk Analysis		
Likelihood	**Consequence**	**Residual Risk Rating**
3 (Possible)	3 (Moderate)	MEDIUM
Risk Treatment		
Mitigations	• Vendor risk management program • Security audits of third parties • Data sharing minimization • Legal compliance clauses	
Risk Monitoring and Review		
Risk Owner	Vendor Management System	

To	management@retailnova.com
Cc	itsecurity@retailnova.com
Bcc	audit@retailnova.com
Subject	**Subject:** Identification of Key Cybersecurity Risks at RetailNova Dear Sir/Madam, I am writing to inform you about three major cybersecurity risks identified during the recent assessment of RetailNova's systems. The first risk involves phishing attacks that may lead to credential compromise. Employees could be targeted through malicious emails, allowing attackers to gain unauthorized access to critical systems such as CRM and internal platforms. The second risk is related to third-party vendors. Weak security controls at external partners may result in data leakage, as previously experienced, potentially exposing sensitive customer information and harming the company's reputation. The third risk concerns ransomware attacks on internal systems, including POS systems, SAP, and cloud infrastructure. Such attacks could cause severe operational disruption, financial losses, and downtime if not properly mitigated. These risks are categorized as high to extreme and require immediate attention. It is recommended to implement stronger security measures such as multi-factor authentication, enhanced vendor risk management, and advanced endpoint protection.

Kindly review these findings and consider appropriate actions to mitigate the identified risks.

Thank you for your attention.

Yours sincerely,
Souvik Dutta
Cybersecurity Analyst
RetailNova Pty Ltd

Risk Details			
Risk ID	R003	**Date Identified**	18/03/2026
Risk Title	Ransomware Infection	**Review Date**	18/06/2026
Risk Identification			
Risk Description	Malware could encrypt company systems causing downtime and financial loss		
Assets at Risk	POS systems, ERP (SAP), AWS infrastructure		
Threat	Cybercriminals (ransomware groups)		
Vulnerability	BYOD risks, endpoint security gaps		
Existing Controls	Antivirus, firewall		

Inherent Risk Analysis		
Likelihood	**Consequence**	**Inherent Risk Rating**
4 (Likely)	5 (Extreme)	EXTREME
Residual Risk Analysis		
Likelihood	**Consequence**	**Residual Risk Rating**
3 (Possible)	4 (Major)	HIGH
Risk Treatment		

Mitigations	• Endpoint Detection & Response (EDR) • Regular backups (offline) • Network segmentation • Patch management
Risk Monitoring and Review	
Risk Owner	IT Operations Team

To	management@retailnova.com
Cc	itsecurity@retailnova.com
Bcc	audit@retailnova.com
Subject	**Subject:** Identification of Key Cybersecurity Risks at RetailNova Dear Sir/Madam, I am writing to inform you about three major cybersecurity risks identified during the recent assessment of RetailNova's systems. The first risk involves phishing attacks that may lead to credential compromise. Employees could be targeted through malicious emails, allowing attackers to gain unauthorized access to critical systems such as CRM and internal platforms. The second risk is related to third-party vendors. Weak security controls at external partners may result in data leakage, as previously experienced, potentially exposing sensitive customer information and harming the company's reputation. The third risk concerns ransomware attacks on internal systems, including POS systems, SAP, and cloud infrastructure. Such attacks could cause severe operational disruption, financial losses, and downtime if not properly mitigated. These risks are categorized as high to extreme and require immediate attention. It is recommended to implement stronger security measures such as multi-factor authentication, enhanced vendor risk management, and advanced endpoint protection. Kindly review these findings and consider appropriate actions to mitigate the identified risks. Thank you for your attention. Yours sincerely, Souvik Dutta Cybersecurity Analyst RetailNova Pty Ltd

Cybersecurity Risk Prioritisation Matrix

Understanding the Likelihood Rating

The table below provides the categories and ratings for likelihood:

Likelihood Ratings	Description	Criteria
Rare (1)	Exceptional circumstances only	May occur only in very unusual situations
Unlikely (2)	Possible, but not expected	Could happen but not typical; requires specific conditions (e.g. targeted phishing bypassing all filters).
Possible (3)	Might occur at some point	Has occurred in similar organisations; realistic but not frequent (e.g. ransomware attempt on enterprise endpoint).
Likely (4)	Will probably occur in most circumstances	Expected to happen periodically (e.g. phishing emails, credential stuffing attempts).
Almost Certain (5)	Expected to occur frequently	Has occurred multiple times, highly predictable (e.g. malware probes, daily scanning activity).

Understanding the Consequence Ratings Table

The table below provides the categories and ratings for impacts:

Consequence Rating	Description	Criteria
Insignificant (1)	Negligible impact	No compromise of sensitive data, no disruption, minimal financial or reputational impact.
Minor (2)	Small impact	Limited operational disruption; minimal data exposure (non-sensitive data); easily contained.
Moderate (3)	Noticeable impact	Partial service disruption; limited sensitive data exposure; moderate cost or compliance breach.
Major (4)	Severe impact	Significant outage of critical systems; large-scale sensitive data breach; regulatory non-compliance with penalties.
Extreme (5)	Catastrophic impact	Extended enterprise-wide outage; compromise of PROTECTED/SECRET data; severe financial/reputational damage; possible criminal or regulatory prosecution.

The 5x5 Risk Matrix

Use this 5x5 risk matrix to evaluate and prioritise cybersecurity risks. For each identified risk, assess its likelihood (1 = Rare, 5 = Almost Certain) and impact (1 = Insignificant, 5 = Critical). Plot the risk in the matrix and use the result to guide mitigation priorities.

Risk Levels

Likelihood ↓ Impact →	Insignificant (1)	Minor (2)	Moderate (3)	Major (4)	Extreme (5)
5 – Almost Certain	**MEDIUM**	**HIGH**	**HIGH**	**EXTREME**	**EXTREME**
4 – Likely	**MEDIUM**	**MEDIUM**	**HIGH**	**HIGH**	**EXTREME**
3 – Possible	**LOW**	**MEDIUM**	**MEDIUM**	**HIGH**	**HIGH**
2 – Unlikely	**LOW**	**LOW**	**MEDIUM**	**MEDIUM**	**HIGH**
1 – Rare	**LOW**	**LOW**	**LOW**	**MEDIUM**	**MEDIUM**

- **Low** – Acceptable; manage by routine controls and monitoring.
- **Medium** – Requires management attention; additional controls may be needed.
- **High** – Significant; must be treated with priority, monitored closely, and escalated to senior management.
- **Extreme** – Unacceptable; immediate executive-level attention and remediation required.